The Open Group Preliminary Standard

O-PAS™ Standard, Version 2.1

Part 2 – Security

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Copyright © 2021, The Open Group

No part of this publication may be reproduced, stored in a retrieval system, or transmitted, in any form or by any means, electronic, mechanical, photocopying, recording or otherwise, without the prior permission of the copyright owners.

Any use of this publication for commercial purposes is subject to the terms of the Annual Commercial License relating to it. For further information, see www.opengroup.org/legal/licensing.

The Open Group Preliminary Standard

O-PAS™ Standard, Version 2.1: Part 2 – Security

Document Number: P210-2

Published by The Open Group, May 2021.

Comments relating to the material contained in this document may be submitted to:

The Open Group, Apex Plaza, Forbury Road, Reading, Berkshire, RG1 1AX, United Kingdom

or by electronic mail to:

ogspecs@opengroup.org

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Contents

1 Introduction 1
- 1.1 Objective 1
- 1.2 Overview 1
- 1.3 Conformance 2
- 1.4 Normative References 2
- 1.5 Terminology 4
- 1.6 Future Directions (Informative) 4

2 Terms and Definitions 5
- 2.1 OPAF Glossary and Abbreviations 5
- 2.2 Terms Specific to Part 2 5

3 Security Architecture Framework 6
- 3.1 Context 6
- 3.2 Security Objectives 6
- 3.3 Security Controls 7
- 3.4 Overarching Security Reference Standard 8
- 3.5 Security Scope 9
- 3.6 Security Level 11
- 3.7 Conformance 12

4 Evaluation of Security Functionality 13
- 4.1 Overview 13
  - 4.1.1 Testing Agreements 13
- 4.2 O-PAS Part 4 – O-PAS Connectivity Framework (OCF) 14
  - 4.2.1 Mapping of OPC UA Parts to the ANSI/ISA 62443 Standard 14
  - 4.2.2 OPC UA Security Conformance Units 15
  - 4.2.3 Security of Time Synchronization Profiles 15
  - 4.2.4 Gap Assessment 16
- 4.3 O-PAS Part 5 – System Management 16
  - 4.3.1 Mapping of Redfish to the ANSI/ISA 62443 Standard 16
  - 4.3.2 Assessment of Redfish Schema Security Functionality 16
  - 4.3.3 Gap Assessment 17
- 4.4 O-PAS Part 6 – Information and Exchange Models 18
  - 4.4.1 Mapping Download/Upload and Import/Export Formats to ANSI/ISA 62443 18
  - 4.4.2 Gap Assessment 19
- 4.5 O-PAS Part 7 – Distributed Control Platform 20
  - 4.5.1 Mapping of Distributed Control Platform to ANSI/ISA-62443-4-2 20
  - 4.5.2 Gap Assessment 21

A SEC-F-001 Security Facet (Normative) 22

B Overview of OPC UA Functionality (Informative) 26

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

C Overview of Redfish Functionality (Informative) 38
D Abbreviations 44
D.1 Abbreviations Specific to Part 2 44

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Preface

The Open Group

The Open Group is a global consortium that enables the achievement of business objectives through technology standards. Our diverse membership of more than 800 organizations includes customers, systems and solutions suppliers, tools vendors, integrators, academics, and consultants across multiple industries.

The mission of The Open Group is to drive the creation of Boundaryless Information Flow™ achieved by:

- Working with customers to capture, understand, and address current and emerging requirements, establish policies, and share best practices
- Working with suppliers, consortia, and standards bodies to develop consensus and facilitate interoperability, to evolve and integrate specifications and open source technologies
- Offering a comprehensive set of services to enhance the operational efficiency of consortia
- Developing and operating the industry's premier certification service and encouraging procurement of certified products

Further information on The Open Group is available at www.opengroup.org.

The Open Group publishes a wide range of technical documentation, most of which is focused on development of Standards and Guides, but which also includes white papers, technical studies, certification and testing documentation, and business titles. Full details and a catalog are available at www.opengroup.org/library.

This Document

This document is Part 2 of the O-PAS™ Standard, Version 2.1, a Preliminary Standard of The Open Group. It has been developed and approved by The Open Group.

The O-PAS Standard consists of the following 12 parts (of the anticipated 13 parts):

- O-PAS Part 1 – Technical Architecture Overview (Informative)
- O-PAS Part 2 – Security (this document)
- O-PAS Part 3 – Profiles (Informative)
- O-PAS Part 4 – O-PAS Connectivity Framework (OCF)
- O-PAS Part 5 – System Management
- O-PAS Part 6.1 – Information and Exchange Models: Overview and Interfaces

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

- O-PAS Part 6.2 – Information and Exchange Models: Basic Configuration
- O-PAS Part 6.3 – Information and Exchange Models: Alarm and Events Configuration
- O-PAS Part 6.4 – Information and Exchange Models: Function Blocks
- O-PAS Part 6.5 – Information and Exchange Models: IEC 61499
- O-PAS Part 6.6 – Information and Exchange Models: IEC 61131
- O-PAS Part 7 – Distributed Control Platform

The parts listed above are separate documents that can be updated and re-versioned as required as we move forward with the O-PAS Standard.

The O-PAS Standard, Version 2.1 is being published initially as a Preliminary Standard since it addresses an emerging area of technology; therefore, it may change before being published as a full standard of The Open Group. In such a case it will be made as upwards-compatible as possible with the corresponding Preliminary Standard, but complete upwards-compatibility is not guaranteed.

Once this document becomes a full standard, it will supersede the O-PAS Standard, Version 1.0 published in December 2019.

Conventions

A Glossary and Abbreviations reference is available. If a term is not defined in that document then the common English definition, as defined in Merriam-Webster's Collegiate Dictionary, applies.

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Trademarks

ArchiMate, DirecNet, Making Standards Work, Open O logo, Open O and Check Certification logo, Platform 3.0, The Open Group, TOGAF, UNIX, UNIXWARE, and the Open Brand X logo are registered trademarks and Boundaryless Information Flow, Build with Integrity Buy with Confidence, Commercial Aviation Reference Architecture, Dependability Through Assuredness, Digital Practitioner Body of Knowledge, DPBoK, EMMM, FACE, the FACE logo, FHIM Profile Builder, the FHIM logo, FPB, Future Airborne Capability Environment, IT4IT, the IT4IT logo, O-AA, O-DEF, O-HERA, O-PAS, Open Agile Architecture, Open FAIR, Open Footprint, Open Process Automation, Open Subsurface Data Universe, Open Trusted Technology Provider, OSDU, Sensor Integration Simplified, SOSA, and the SOSA logo are trademarks of The Open Group.

JavaScript is a trademark of Oracle Corporation and/or its affiliates.

Redfish is a registered trademark of Distributed Management Task Force, Inc.

All other brands, company, and product names are used for identification purposes only and may be trademarks that are the sole property of their respective owners.

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Acknowledgements

The Open Group gratefully acknowledges the International Society of Automation for use of the ISA copyrighted ANSI/ISA 62443 standard. Visit www.isa.org.

The Open Group acknowledges DMTF as copyright owner of the Redfish® standard, which is used in the O-PAS Standard. DMTF is a not-for-profit association of industry members dedicated to promoting enterprise and systems management and interoperability. Members and non-members may reproduce DMTF specifications and documents for uses consistent with this purpose, provided that correct attribution is given. Additional information is available at: www.dmtf.org/about/policies/copyright.

The Open Group gratefully acknowledges and thanks the OPC Foundation for the template used to develop an OPC UA Companion Specification that is included in this O-PAS Standard.

The Open Group gratefully acknowledges the contribution of the following people in the development of this document:

Lead Contributors

- Camilo Gomez – Yokogawa Electric Corporation (Subcommittee Lead)
- Timothy Mirth – Rockwell Automation (Subcommittee Lead)

Additional Contributors

- Niaz Ahamed – Shell
- Ron Breault – Wind River Systems, Inc.
- Craig Griffin – Wind River Systems, Inc.
- Kirk Hansen – Enterprise Transformation Partners
- Dan Holme – Cisco
- Paul Hunkar – Yokogawa Electric Corporation
- James Luth – Schneider Electric
- Mark McCollum – ExxonMobil
- Santosh Suryawanshi – Tata Consultancy Services

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

The Open Group gratefully acknowledges the contribution and leadership of the Co-Chairs of the Open Process Automation™ Forum and Working Groups.

Forum Co-Chairs

- Don Bartusiak – Collaborative Systems Integration, LLC
- Trevor Cusworth – Schneider Electric

Business Working Group Co-Chair

- Luis Duran – ABB Automation GmbH
- Jacco Opmeer – Shell

Enterprise Architecture Work Grouping Co-Chairs

- Dave Emerson – Yokogawa Electric Corporation
- Harirajan Padmanabhan – hpad, Inc.

Technology Working Group Co-Chairs

- David Fort – Rockwell Automation
- Kirk Smith – Intel Corporation

Certification Working Group Co-Chairs

- Ed Agis – Intel Corporation
- Ron Breault – Wind River Systems, Inc.

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Referenced Documents

The following documents are referenced in Part 2 of the O-PAS Standard.

The documents are referred to in the text in such a way that some or all of their content constitutes requirements of this part. For dated references, only the version cited applies. For undated references, the latest version of the referenced document (including any amendments) applies.

(Please note that the links below are good at the time of writing but cannot be guaranteed for the future.)

Normative References

Normative references for Part 2 of the O-PAS Standard are defined in Section 1.4.

Informative References

- ANSI/ISA-62443-1-1:2007: Security for Industrial Automation and Control Systems – Part 1-1: Terminology, Concepts, and Models (adopted by IEC as IEC 62443-1-1)
- ANSI/ISA-62443-2-1:2009: Security for Industrial Automation and Control Systems – Part 2-1: Establishing an Industrial Automation and Control Systems Security Program (adopted by IEC as IEC 62443-2-1)
- ANSI/ISA-TR62443-2-3:2015: Security for Industrial Automation and Control Systems – Part 2-3: Patch Management in the IACS Environment (adopted by IEC as IEC TR 62443-2-3)
- ANSI/ISA-62443-2-4:2018: Security for Industrial Automation and Control Systems – Part 2-4: Security Program Requirements for IACS Service Providers (adopted from IEC 62443-2-4)
- ANSI/ISA-TR99.00.01-2007: Industrial Communication Networks – Network and System Security – Part 3-1: Security Technologies for Industrial Automation and Control Systems (adopted as IEC TR 62443-3-1:2009)
- IEEE 802.1AE, ANSI/IEEE 802.1AE-2006: IEEE Standard for Local and Metropolitan Area Networks: Media Access Control (MAC) Security
- IETF RFC 7384: Security Requirements of Time Protocols in Packet Switched Networks, October 2014; refer to: https://tools.ietf.org/html/rfc7384
- Industrial Internet Consortium: IIC Endpoint Security Best Practices, IIC:WHT:IN17:V1.0:PB:20180312
- Industrial Internet Consortium: Industrial Internet of Things Volume G4: Security Framework, IIC:PUB:G4:V1.0:PB:20160926

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

- Industrial Internet Consortium: IoT Security Maturity Model: Description and Intended Use, IIC:PUB:IN15:V1.0:PB:20180409
- ISO/IEC 27002:2013: Information Technology – Security Techniques – Code of Practice for Information Security Controls
- NIST Federal Information Processing Standard (FIPS) Publication 140-2 (FIPS PUB 140-2): Security Requirements for Cryptographic Modules, May 2001
- NIST Special Publication (SP) 800-53 Rev. 5 (DRAFT): Security and Privacy Controls for Information Systems and Organizations, August 2017
- NIST Special Publication (SP) 800-82 Rev. 2: Guide to Industrial Control Systems (ICS) Security, May 2015
- NIST White Paper: Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1, April 2018
- Redfish®, DMTF; refer to: https://www.dmtf.org/standards/redfish
- Requirements for an Open Process Automation™ Standard, White Paper (W184), May 2018, published by The Open Group; refer to: www.opengroup.org/library/w184
- The Open Process Automation™ Business Guide, The Open Group Guide (G182), January 2018, published by The Open Group; refer to: www.opengroup.org/library/g182

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

1 Introduction

1.1 Objective

The objective of Part 2 of the O-PAS Standard is to define the Security Architecture Framework for the O-PAS Standard, including:

- Identification of the overarching security reference standard (ANSI/ISA 62443: Security for Industrial Automation and Control Systems) for industrial automation and control systems in alignment with the Open Process Automation™ Forum (OPAF) member requirements and industry best practices
- Identification of security requirements in the overarching cybersecurity reference standard applicable to the O-PAS functionality defined in O-PAS Part 4 – O-PAS Connectivity Framework (OCF), O-PAS Part 5 – System Management, O-PAS Part 6 – Information and Exchange Models, and O-PAS Part 7 – Distributed Control Platform
- Evaluation of embedded security functionality in the reference standards defined and used in O-PAS Part 4 – O-PAS Connectivity Framework (OCF), O-PAS Part 5 – System Management, O-PAS Part 6 – Information and Exchange Models, and O-PAS Part 7 – Distributed Control Platform in relation to the overarching cybersecurity standard and the overall Security Architecture

This document expands from cybersecurity in support of the interoperability of components, which was the main objective of the O-PAS Standard, Version 1.0, to cybersecurity in support of configuration portability which is the main objective of the O-PAS Standard, Version 2.1.

1.2 Overview

Cybersecurity is an O-PAS imperative and of utmost importance to OPAF stakeholders. Until now, cybersecurity for the Operations Technology (OT) space has been largely focused on the protection of existing (brownfield) and new (greenfield) implementations. It has been characterized by add-on procedural and technical countermeasures to mitigate security risk and prevent impact to the safety and operation of industrial environments.

An O-PAS environment may be composed of thousands of O-PAS conformant components from multiple vendors. Managing security in such a highly distributed environment requires security to be considered in all elements of the Technical Architecture – from the hardware platform to the applications, passing through the operating system, the communications platform, configuration information, and system management services.

It is important to note that an O-PAS conformant product can be a Distributed Control Node (DCN) and its internal components, or it can be just an O-PAS conformant application in the form of a software program that can be installed on a DCN from any vendor, all of which are subject to security control.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

The O-PAS Standard aims to integrate and maintain security throughout the lifecycle of conformant components.

The use of certified components does not guarantee that the Industrial Automation and Control System (IACS) or the installation will be secure. It is the responsibility of the system integrator and/or end user to assess whether the target security level (as defined in the ANSI/ISA 62443 standards) of the implementation is met.

1.3 Conformance

Conformance requirements (marked with "CRQ" identifiers) related to aspects of the Security Architecture Framework are described in Section 3.7 of this document.

Conformance requirements related to integrated security, functionality, or security features defined in the standards used in O-PAS Part 4 – O-PAS Connectivity Framework (OCF) and O-PAS Part 5 – System Management are defined directly in those documents.

Conformance requirements related to O-PAS Part 6 – Information and Data Exchange Model and O-PAS Part 7 – Distributed Control Platform are defined in Section 4.5 of this document, because the reference standards used in those parts do not define security functions or interfaces.

1.4 Normative References

The following standards contain provisions which, through references in this document, constitute provisions of Part 2 of the O-PAS Standard. At the time of publication, the editions indicated were valid. All standards are subject to revision, and parties to agreements based on this document are encouraged to investigate the possibility of applying the most recent editions of the standards listed below.

- ANSI/ISA-62443-3-3:2013: Security for Industrial Automation and Control Systems – Part 3-3: System Security Requirements and Security Levels (adopted by IEC as IEC 62443-3-3)
- ANSI/ISA-62443-4-1:2018: Security for Industrial Automation and Control Systems – Part 4-1: Product Security Development Lifecycle Requirements (adopted by IEC as IEC 62443-4-1)
- ANSI/ISA-62443-4-2:2018: Security for Industrial Automation and Control Systems – Part 4-2: Technical Security Requirements for IACS Components (adopted by IEC as IEC 62443-4-2)
- IEEE 1588-2008: IEEE Standard for a Precision Clock Synchronization Protocol for Networked Measurement and Control Systems; refer to: https://standards.ieee.org/standard/1588-2008.html
- IEEE 1588-2019: IEEE Approved Draft Standard for a Precision Clock Synchronization Protocol for Networked Measurement and Control Systems; refer to: https://standards.ieee.org/standard/1588-2019.html
- IETF RFC 2119: Key Words for Use in RFCs to Indicate Requirement Levels, March 1997; refer to: https://tools.ietf.org/html/rfc2119

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

- O-PAS Standard, Version 2.1: Part 4 – O-PAS Connectivity Framework (OCF), The Open Group Preliminary Standard (P210-4), May 2021, published by The Open Group; refer to: www.opengroup.org/library/p210
- O-PAS Standard, Version 2.1: Part 5 – System Management, The Open Group Preliminary Standard (P210-5), May 2021, published by The Open Group; refer to: www.opengroup.org/library/p210
- O-PAS Standard, Version 2.1: Part 6.1 – Information and Exchange Models: Overview and Interfaces, The Open Group Preliminary Standard (P210-6a), May 2021, published by The Open Group; refer to: www.opengroup.org/library/p210
- O-PAS Standard, Version 2.1: Part 6.2 – Information and Exchange Models: Basic Configuration, The Open Group Preliminary Standard (P210-6b), May 2021, published by The Open Group; refer to: www.opengroup.org/library/p210
- O-PAS Standard, Version 2.1: Part 6.4 – Information and Exchange Models: Function Blocks, The Open Group Preliminary Standard (P210-6d), May 2021, published by The Open Group; refer to: www.opengroup.org/library/p210
- O-PAS Standard, Version 2.1: Part 6.5 – Information and Exchange Models: IEC 61499, The Open Group Preliminary Standard (P210-6e), May 2021, published by The Open Group; refer to: www.opengroup.org/library/p210
- O-PAS Standard, Version 2.1: Part 6.6 – Information and Exchange Models: IEC 61131, The Open Group Preliminary Standard (P210-6f), May 2021, published by The Open Group; refer to: www.opengroup.org/library/p210
- O-PAS Standard, Version 2.1: Part 7 – Distributed Control Platform, The Open Group Preliminary Standard (P210-7), May 2021, published by The Open Group; refer to: www.opengroup.org/library/p210
- Redfish® Scalable Platforms Management API Specification, DSP0266 V1.6.0, DMTF
- Redfish® Scalable Interoperability Profile Specification, DSP0272 V1.0.1, DMTF
- Redfish® Resource and Schema Guide, DSP8010 V2018.2, DMTF
- Unified Architecture (UA) Specification, Part 2: Security Model (also IEC 62541-2:2016), OPC Foundation; refer to: http://www.opcfoundation.org/UA/Part2/
- Unified Architecture (UA) Specification, Part 4: Services (also IEC 62541-4:2015), OPC Foundation; refer to: http://www.opcfoundation.org/UA/Part4/
- Unified Architecture (UA) Specification, Part 5: Information Model (also IEC 62541-5:2015), OPC Foundation; refer to: http://www.opcfoundation.org/UA/Part5/
- Unified Architecture (UA) Specification, Part 6: Mappings (also IEC 62541-6:2015), OPC Foundation; refer to: http://www.opcfoundation.org/UA/Part6/
- Unified Architecture (UA) Specification, Part 7: Profiles (also IEC 62541-7:2015), OPC Foundation; refer to: http://www.opcfoundation.org/UA/Part7/
- Unified Architecture (UA) Specification, Part 12: Discovery and Global Services (also IEC 62541-12), OPC Foundation; refer to: http://www.opcfoundation.org/UA/Part12/

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

- Unified Architecture (UA) Specification, Part 14: PubSub (also IEC 62541-14), OPC Foundation; refer to: https://opcfoundation.org/developer-tools/specifications-unified-architecture/part-14-pubsub

1.5 Terminology

The key words “shall”, “shall not”, and “should” are used in the O-PAS Standard as defined below. These definitions are taken from IETF RFC 2119.

Shall	Definition is an absolute requirement of the specification.
Shall not	Definition is an absolute prohibition of the specification.
Should	There may exist valid reasons in particular circumstances to ignore a particular item, but the full implications must be understood and carefully weighed before choosing a different course.

1.6 Future Directions (Informative)

The contents and security scope of Part 2 of the O-PAS Standard are directly related to the scope and overall functional objectives of the O-PAS Standard, Version 2.1.

A future version of the O-PAS Standard will address additional functionality such as software portability, software application management, proprietary information, role-based access, security and audit logs, secure development environment, and extended physical platform functionality. At that time, Part 2 will be revised and updated accordingly.

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

2 Terms and Definitions

For the purposes of the O-PAS Standard, the following terms and definitions apply. Merriam-Webster's Collegiate Dictionary should be referenced for terms not defined in this chapter. The OPAF Glossary and Abbreviations should be referenced for additional terms not defined in this chapter.

2.1 OPAF Glossary and Abbreviations

For the OPAF Glossary and Abbreviations, see the definitions at: www.opengroup.org/open-process-automation-forum/glossary.

2.2 Terms Specific to Part 2

The following terms are specific to O-PAS Part 2 (and therefore do not appear in the OPAF Glossary referenced in Section 2.1).

Term	Definition
Common Component Security Constraint	Common constraints to be applied and adhered to during implementation of the requirements prescribed by the ANSI/ISA 62443-4-2 standard.
Foundational Requirement	Categories of security controls or settings that form the basis for technical requirements in the ANSI/ISA 62443 standard.
Component Requirement	Technical requirements applicable to control systems components as defined in the ANSI/ISA 62443-4-2 standard. Note: Per that specification there are four types of components: software application, embedded device, host device, and network device.
Requirements Enhancement	Technical enhancement of component requirements (CR) defined in the ANSI/ISA 62443-4-2 standard required to achieve higher degree of security level for the CR under consideration.
Software Application	Technical requirements specifically applicable to software application type components as defined in the ANSI/ISA 62443-4-2 standard.
Embedded Device Requirement	Technical requirements specifically applicable to embedded device type components as defined in the ANSI/ISA 62443-4-2 standard.
Host Device Requirement	Technical requirements specifically applicable to host device type components as defined in the ANSI/ISA 62443-4-2 standard.
Network Device Requirement	Technical requirements specifically applicable to network device type components as defined in the ANSI/ISA 62443-4-2 standard.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

3 Security Architecture Framework

3.1 Context

The foundational quality attributes of the O-PAS Technical Architecture are safety, reliability, and security of process IACS. They are not to be compromised. With the potential of tens of thousands of nodes and applications in an O-PAS conformant environment, security ought to be done without extensive manual intervention, through secure communication between elements, and ensuring that only valid and authorized secure commands are executed. Thus, security needs to be designed-in and integrated in all aspects of the architecture.

The purpose of this Security Architecture Framework is to describe the overarching security concepts and elements that product suppliers need to integrate and address when developing O-PAS conformant products.

Cybersecurity is an important consideration for any type of organization to protect against loss of revenue and reputation from a security breach. In an IACS, it plays an especially critical role in preventing product and equipment damage, or even potential disasters ranging from food and water contamination to nuclear meltdowns. Such a system will need to take advantage of future state technologies based on Industrial Internet of Things (IIoT) connectivity and off-premise cloud services. This is the motivation for the secure-by-design vision.

3.2 Security Objectives

As threats to critical infrastructure are becoming more prevalent it is imperative for these systems to achieve a certain level of security by utilizing components that have the following security objectives designed into them:

- **Availability** is the property of ensuring timely and reliable access to and use of control system information and functionality

  Availability against security-related outages can be achieved through implementation of Denial of Service (DoS) mitigations, redundant communication paths, and unauthorized-access mitigations.

- **Integrity** is the property of protecting the accuracy and completeness of assets, and the guarding against improper modification or destruction of data

  Integrity is usually implemented by comparing hashes of the data at different points in time to ensure nothing has changed.

- **Confidentiality** is the assurance that information is not disclosed to unauthorized individuals, processes, or devices

  Confidentiality is typically achieved through encryption such that only authorized parties have the information needed to decrypt and access the data.

- **Identification**, **Authentication**, and **Authorization** are inter-related:

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

— **Identification** is the ability to uniquely identify each entity acting on a system for the purposes of authentication, authorization, and auditability

— **Authentication** is the ability to prove that a system actor is who they claim to be

— **Authorization** defines which operations an actor is allowed to perform on a given resource

- **Non-repudiation** is a security service that provides:

  — Protection against false denial of involvement in a communication

  — The ability to prove the occurrence of a claimed event or action and its originating entities

  — Assurance that the sender of information is provided with proof of delivery and the recipient is provided with proof of the sender's identity, so neither can later deny having processed the information

- **Auditability** and **Accountability** are the results of logging taken on a system in order to ensure that the actions of a system entity may be traced uniquely to that entity, which can be held responsible for its actions

  The resulting logs can be used to detect anomalies and perform root-cause analysis after an incident occurs. They are also used in proving adherence to standards and regulations during audits.

3.3 Security Controls

Some of the controls used to implement the security objectives, outside of the component specifications defined in the O-PAS Standard, include:

- **Segmentation** is the act of dividing the system network into different sections or zones based on trust levels and other security attributes in order to place access restrictions, or to define different security objectives, security targets, or security levels on each zone

  The benefit of this network segmentation is to limit the damage a malicious actor can do once they have breached a system. Network segmentation is typically accomplished with firewalls and Virtual Local Area Networks (VLANs).

- **Anomaly Detection** involves monitoring the system for behavior or data that is significantly different from the desired or normal events and state of the system

  These anomalies often indicate some sort of problem within the system. Anomaly detection is typically done by applications built for this specific purpose.

- **Incident Response** is the process for managing the aftermath of a security breach or cyber-attack with the goal of limiting damage and reducing recovery time and cost

  This can include some automated components, but typically involves a manual process for assessing the situation and determining the best strategic course of action.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

3.4 Overarching Security Reference Standard

The O-PAS Standard defers to the ANSI/ISA 62443 standards as the overarching security reference standard. The ANSI/ISA 62443 standards are known as the global standard for security of an IACS. It is a robust series of standards that covers all aspects of securing an IACS at both the component and system level throughout its lifecycle.

Figure 1 shows that at a high-level the foundational requirements of the ANSI/ISA 62443 standard map to all the O-PAS objectives, making it a good choice of reference standard to define what is required for securing an O-PAS component. The columns identify the ANSI/ISA 62443 foundational requirements, and the rows identify the O-PAS objectives. The blue dots indicate where the ANSI/ISA 62443 foundational requirements map to the O-PAS objectives.

ANSI/ISA 62443 Series Foundational Requirements

O-PAS Objectives	FR1 Identification & Authentication Control	FR2 Use Control	FR3 System Integrity	FR4 Data Confidentiality	FR5 Restricted Data Flow	FR6 Timely Response to Events	FR7 Resource Availability
Identification	●						
Authentication	●						
Non-repudiation	●	●					
Authorization		●					
Integrity			●				
Anomaly Detection			●				
Confidentiality				●			
Segmentation					●		
Auditability/Accountability						●	
Availability							●
Incident Response							●

Figure 1: Mapping to ANSI/ISA 62443 Foundational Requirements

In addition, the O-PAS Standard was developed using the following key requirements proposed by the OPAF end-user members:

- The O-PAS architecture takes advantage of existing industry standards whenever this is possible, practical, and consistent with achieving the goals of the O-PAS Standard
- O-PAS components meet or exceed the requirements for Security Level 2 (see Section 3.6), as stated in the ANSI/ISA 62443 standards

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

By using the ANSI/ISA 62443 standard as a reference standard, the O-PAS security architecture meets all of these key end-user requirements. When this document refers to an ANSI/ISA 62443 requirement, it is the reader's responsibility to refer to the ANSI/ISA 62443 standard for details. Those interested in participating in development of O-PAS components are responsible for referring to the ANSI/ISA 62443 standards for the content of the requirements included therein.

3.5 Security Scope

As illustrated in Figure 2, the ANSI/ISA 62443 standard is a comprehensive collection of parts intended to address the security needs of the different stakeholders in an IACS environment and supply chain. Stakeholders include asset owners, service providers, system integrators, and product suppliers.

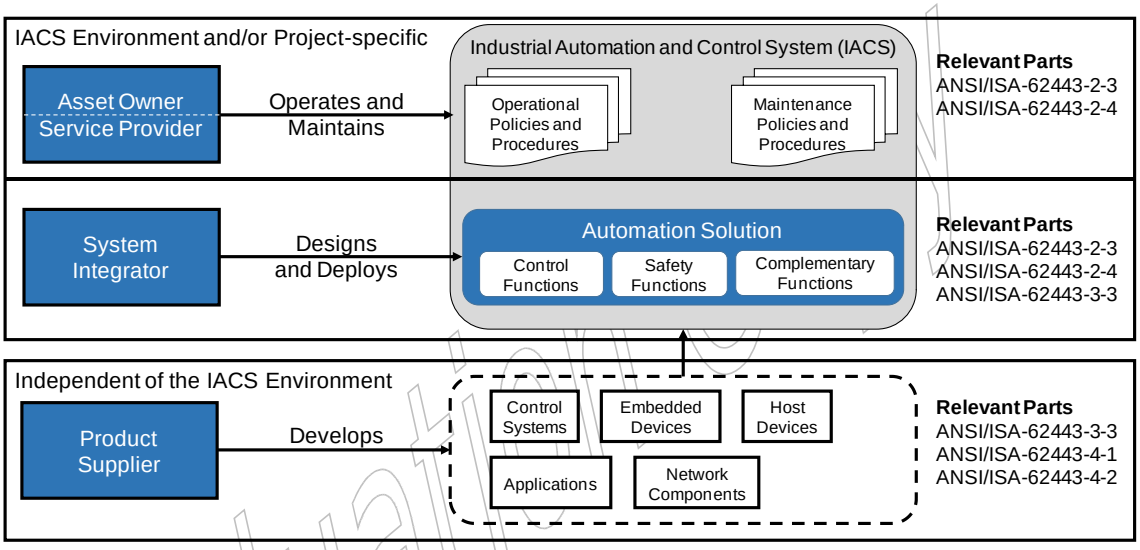

Figure 2: Grouping of ANSI/ISA 62443 Parts

As shown in Figure 3, the purpose of the O-PAS architecture is to define, build, and maintain IACS components in the form of O-PAS conformant DCN devices and software applications, independently of any specific IACS environment or project. Refer to the Open Process Automation Business Guide for details on the lifecycle stages.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

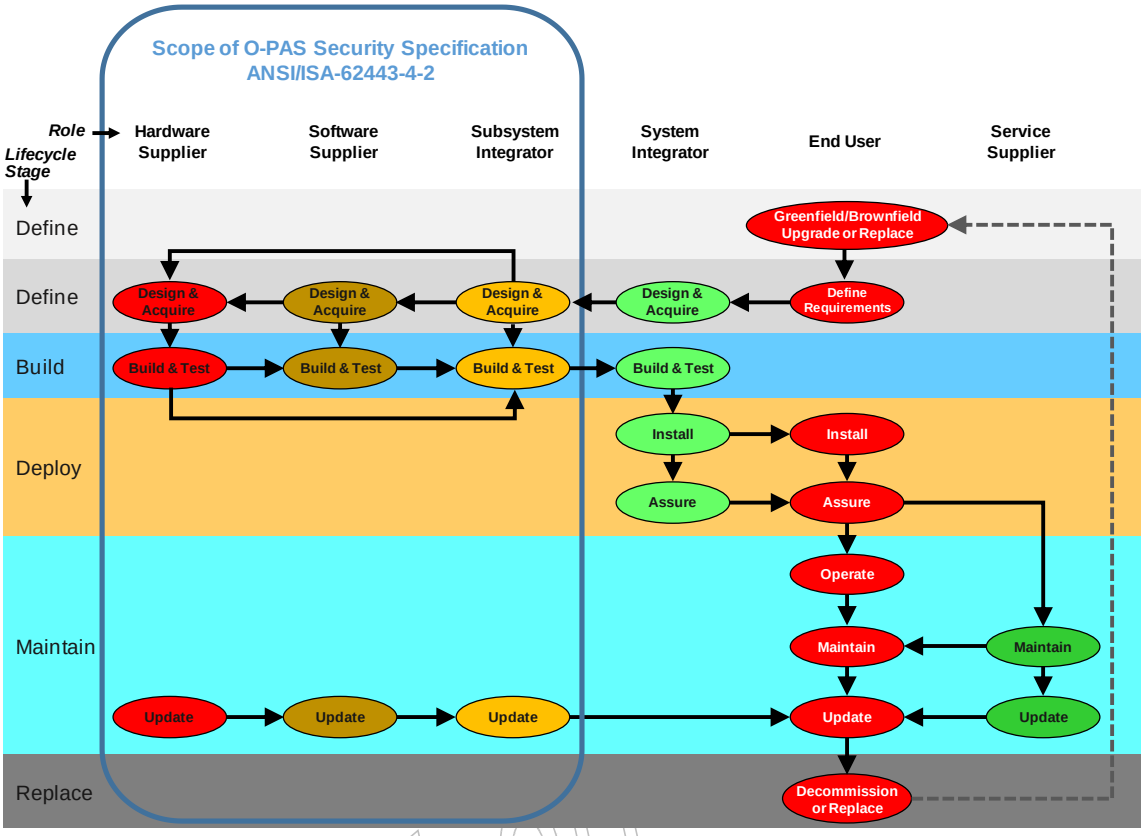

Figure 3: O-PAS Lifecycle and Security Scope

In consequence, the ANSI/ISA 62443-relevant part in scope for the O-PAS Security Architecture Framework is:

- ANSI/ISA-62443-4-2:2018: Security for Industrial Automation and Control Systems – Part 4-2: Technical Security Requirements for IACS Components (adopted by IEC as IEC 62443-4-2)

Notice, however, as illustrated in Figure 2, that there are two other ANSI/ISA-62443 parts related to the Product Supplier associated with the ANSI/ISA-62443-4-2 component security part that are indirectly relevant:

- ANSI/ISA-62443-3-3:2013: Security for Industrial Automation and Control Systems – Part 3-3: System Security Requirements and Security Levels (adopted by IEC as IEC 62443-3-3)

  Related to technical security requirements for systems. Applicable to supplier organizations planning to build systems and subsystems made of O-PAS components.

- ANSI/ISA-62443-4-1:2018: Security for Industrial Automation and Control Systems – Part 4-1: Product Security Development Lifecycle Requirements (adopted by IEC as IEC 62443-4-1)

  Related to procedural requirements in the lifecycle for product security development and maintenance applicable to organizations developing components and systems, and a prerequisite of ANSI/ISA-62443-4-2.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

3.6 Security Level

Security Level (SL) is a key concept for the O-PAS Standard, as it has to do with the level of cybersecurity protection that a component is capable of.

As defined in ANSI/ISA-62443-3-3, there are three different types of SL:

1. Target SL (SL-T): Desired level of security for a particular automation solution. Defined by the asset owner, or defined by the system integrator/service provider in conjunction with the asset owner based on risk assessment.
2. Capability SL (SL-C): Security level that a component can provide when properly configured. Defined by the product supplier. Demonstrable through conformance testing or certification.
3. Achieved SL (SL-A): Actual level of security for a particular IACS after implementation. Demonstrable by the system integrator/service provider to the asset owner.

Notice the difference between the three. For the purpose of the O-PAS Standard, Security Level (SL) refers to Capability SL (SL-C).

The ANSI/ISA 62443 standard defines five security levels: the higher the number, the higher the level of protection. They are defined as follows:

- SL0: no security protection necessary/provided
- SL1: capable of protecting against casual or coincidental violation
- SL2: capable of protecting against intentional violation using simple means with low resources, generic skills, and low motivation
- SL3: capable of protecting against intentional violation using sophisticated means with moderate resources, IACS-specific skills, and moderate motivation
- SL4: capable of protecting against intentional violation using sophisticated means with extended resources, IACS-specific skills, and high motivation

In order to meet the interoperability and portability requirements targeted for the O-PAS Standard, Version 2.1, components need to meet ANSI/ISA-62443-4-2 SL2 capability as a minimum. This is because there are certain requirements for SL2 and above that are not able to interoperate with SL1-only capability. For example, SL2 and above require that the system under test rejects any usage of invalid session IDs. A session meeting only SL1 requirements might use a session ID that would be deemed invalid for SL2 and above. See Appendix A for a list of security requirements.

The fact that O-PAS products must meet SL2 does not limit product suppliers to SL2. Product suppliers can build products with higher SL capability as required by asset owners. Higher security capability levels (above SL2) are not in the scope of the O-PAS Standard.

Asset owners who choose to incorporate components with lower SL must accept the risks that the lower SL component brings to the security integrity of their system.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

3.7 Conformance

The aim of this Security Architecture Framework is to ensure:

- Security functionality is integrated into O-PAS components (i.e., devices and applications)
- Security is designed in all stages of the product lifecycle
- Specification of interfaces that provide the necessary security controls will meet both O-PAS functionality and security requirements in ANSI/ISA-62443-4-2

Regarding cybersecurity conformance for the O-PAS Standard, Version 2.1, product suppliers developing O-PAS conformant products shall implement the ANSI/ISA-62443-4-2 component security requirements identified in the Security Facet SEC-F-001 of this document (see Appendix A for CRQs).

Product suppliers are advised to plan to address any ANSI/ISA-62443-4-2 prerequisite requirements such as conformance with ANSI/ISA-62443-4-1 Product Security Development Lifecycle Requirements applicable to the product supplier organization, which will be required in the future.

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

4 Evaluation of Security Functionality

4.1 Overview

This section contains an evaluation of security-related functionality (and/or any gaps) defined in other parts of the O-PAS Standard against requirements in the ANSI/ISA-62443-4-2 cybersecurity reference standard, as follows:

- Section 4.2 provides an assessment of security-related features in the OPC Unified Architecture (UA) standard against security requirements in the ANSI/ISA-62443-4-2 standard; OPC UA is the reference standard used in O-PAS Part 4 – O-PAS Connectivity Framework (OCF)
- Section 4.3 provides an assessment of security-related features in the Redfish® standard against security requirements in the ANSI/ISA-62443-4-2 standard; Redfish is the reference standard used in O-PAS Part 5 – System Management
- Section 4.4 provides details of security requirements defined in ANSI/ISA-62443-4-2 necessary to protect configuration data while in transit and at rest as required by the import/export and download/upload models described in O-PAS Part 6 – Information and Exchange Models
- Section 4.5 provides details of security requirements defined in ANSI/ISA-62443-4-2 relevant to O-PAS Part 7 – Distributed Control Platform

4.1.1 Testing Agreements

The Open Group has executed a formal agreement with the ISASecure[1] organization whereby ISASecure will have the ability and authority to execute security testing on the elements of ANSI/ISA-62443-4-2 required by OPAF (see Figure 4). Companies who desire to demonstrate their O-PAS security requirements conformance must commercially engage The Open Group and ISASecure – or any other accredited verification authority that may be so designated by The Open Group – for this effort.

[1] See www.isasecure.org.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

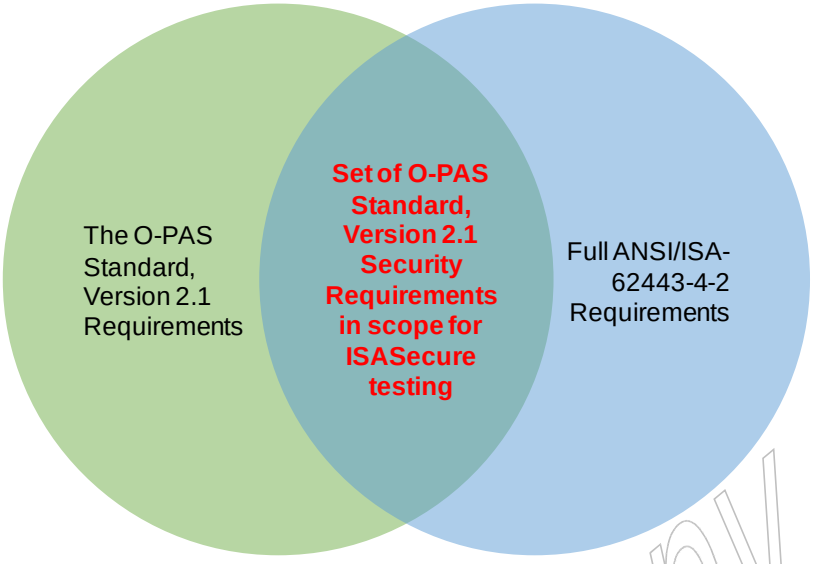

Figure 4: The O-PAS Standard, Version 2.1 Security Requirements in Testing Scope

Upon successful completion of testing (100% conformance to the required O-PAS Standard, Version 2.1 security requirements), ISASecure would convey conformance to The Open Group. To be clear, this is not an ISASecure certification, but a statement of formal conformance to the applicable O-PAS security requirements. The Open Group would then take this security conformance into consideration for formal O-PAS certification (together with any other conformance requirements, depending on the selected O-PAS Profile).

Note: For product suppliers considering more broad certification (e.g., ANSI/ISA-62443-4-2), note that the ANSI/ISA-62443-4-1 standard is a prerequisite to ANSI/ISA-62443-4-2 certification. To be clear, neither ANSI/ISA-62443-4-1 nor ANSI/ISA-62443-4-2 certification is required by the O-PAS Standard, Version 2.1 but both are considered desirable.

4.2 O-PAS Part 4 – O-PAS Connectivity Framework (OCF)

4.2.1 Mapping of OPC UA Parts to the ANSI/ISA 62443 Standard

The Unified Architecture (UA) specification is published by the OPC Foundation and is composed of multiple parts. The OPC UA Specification: Part 2 – Security Model defines the security model for securing communications between OPC UA applications. However, detailed descriptions of security features are distributed throughout other parts of the specification.

Implementations of OPC UA client/server and PubSub software will be common in O-PAS components. Thus, security vulnerabilities in this software could affect an entire automation solution. The OPC UA specification has a rich set of security features that can be utilized to mitigate this risk. A mapping of these features was performed against ANSI/ISA-62443-4-2 to determine gaps against the set of SL2 requirements.

Appendix B provides mapping of OPC UA security-related functionality described in O-PAS Part 4 – O-PAS Connectivity Framework (OCF) against the ANSI/ISA-62443-4-2 SL2 requirements.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

4.2.2 OPC UA Security Conformance Units

In the OPC UA specification, security functionality is defined as conformance units, facets, and/or profiles. An OPC UA conformance unit is a specific set of features that can be tested as a single entity.

Refer to O-PAS Part 4 – O-PAS Connectivity Framework (OCF) for the set of OPC UA profiles, facets, and conformance units used by the O-PAS Profiles defined in that part.

4.2.3 Security of Time Synchronization Profiles

O-PAS Part 4 – O-PAS Connectivity Framework (OCF) identifies IEEE 1588-2008 as the mandatory standard for time synchronization for profiles except non-Time-Sensitive Networking (TSN)-based profiles. This includes the media-independent time synchronization profile, and the Ethernet-based time synchronization profile.

The IEEE 1588-2008 standard has been recently superseded by IEEE 1588-2019, which will be reviewed and considered for adoption in a future version of the O-PAS Standard. A detailed analysis of security threats and the resulting security requirements for clock synchronization protocols was developed in IETF RFC 7384. The IEEE 1588-2019 standard takes a multi-pronged approach to all of the existing security concerns with IEEE 1588-2008. Annex S of the IEEE 1588-2019 standard holds all security mechanisms, including:

- The standard has a newly defined Threshold Limit Value (TLV) for message and source integrity checking, using various options of manual and centralized key management for authentication purposes; key management can be also be implemented as immediate or delayed, giving options to tailor the implementation for each design paradigm
- Consideration is given to networks where MAC security (IEEE 802.1AE) is implemented to provide point-to-point Ethernet link encryption, or where IP security is used for Layer-3 encryption of packets; either of these methods could be relevant at different points in the O-PAS architecture
- Various architectural and configuration recommendations are made to improve and optimize the security of the timing protocol; these recommendations primarily focus on topological redundancy of timing systems, grandmaster Precision Time Protocol (PTP) systems, and resilient and/or redundant paths between devices
- By monitoring various PTP parameters (meanPathDelay, offsetFromMaster, etc.) and the four PTP timestamps (t1, t2, t3, and t4), it is possible to get an indication of network performance and PTP instance operation, which in turn protects against further malicious manipulation of PTP messages

A future version of the O-PAS Standard may include a deeper analysis of these security mechanisms within the context of the O-PAS architecture. Consideration will also be given to the implementation of PTP and any implications on the design and operation of the DCN.

We may require custom O-PAS PTP profiles for specific O-PAS architecture functions.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

4.2.4 Gap Assessment

There is a known OCF-related gap to be addressed in a future version of the O-PAS Standard, as follows:

- The new IEEE 1588-2019 standard needs to be reviewed and adopted by the OPAF

  Until this specification is reviewed, organizations developing products which follow the two aforementioned O-PAS time synchronization profiles are advised to research the security aspects of IEEE 1588-2008 and mitigate potential risks through other means (network segregation, firewalls, etc.). More specific security recommendations for IEEE 1588-2008 are beyond the scope of this document.

4.3 O-PAS Part 5 – System Management

4.3.1 Mapping of Redfish to the ANSI/ISA 62443 Standard

O-PAS Part 5 utilizes the Redfish standard for defining system management. The Redfish standard is composed of a set of specifications maintained by the Distributed Management Task Force (DMTF). The standard defines a protocol to provide access to data and operations associated with the management of systems and networks. The Redfish standard was designed as an open industry standard for secure system management in multi-vendor deployments which can scale to large numbers of systems. The Redfish standard API easily integrates with commonly used tools, uses RESTful interfaces to perform operations, and uses JavaScript™ Object Notation (JSON) and OData formats for data payloads.

Delivering IACS security for system management depends on both external security service capabilities (such as identity management applications, network firewalls, etc.) and the system management security requirements embedded in the interface standard (in this case, Redfish). The Redfish standard security requirements are driven from the IT industry which has many common requirements with IACS systems, making it a good candidate for this assessment.

As previously discussed, the O-PAS Standard frames security requirements and capabilities for IACS using the ANSI/ISA 62443 standard as a reference standard. While the ANSI/ISA 62443 standards provide a solid foundation for what the security requirements are, they do not specify how these requirements are to be implemented.

4.3.2 Assessment of Redfish Schema Security Functionality

Table 1 provides an overview of the security control foundational requirement areas of the ANSI/ISA 62443 standard and how they can be addressed with the Redfish API capabilities, as follows:

- The first column lists the ANSI/ISA 62443 foundational requirement area
- The second column provides external service dependencies that would be required to interact with Redfish in order to fully meet the requirement
- The third column contains the Redfish API capabilities that are used in meeting the requirement
- The last column contains additional comments on Redfish capabilities

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Table 1: Assessment of Redfish Security Functionality

ANSI/ISA 62443 Foundational Requirement	External Service Dependency	Redfish API Capability	Redfish Compatibility Comment
FR 1: Identification and authentication control	Identity, authentication, security certificates, credential services	Accounts, roles, events, other commands	
FR 2: Use control	Authorization, auditing, time, endpoint security services	Accounts, logs, Network Time Protocol (NTP), sessions, events, other commands	Several controls are delivered from endpoint security services.
FR 3: System integrity	Intrusion detection, identity, audit services, endpoint security services	Protocols, logs, sessions, and other commands	Several controls are delivered from endpoint security services.
FR 4: Data confidentiality	Encryption services	Protocols, logs, sessions, and other commands	
FR 5: Restricted data flow	Enable/disable specific management protocols	Enable/disable HTTP, HTTPS, SSDP, SSH, Telnet, SNMP, RDP, NTP, KVMIP, IPMI, DHCP, DHCPv6	Redfish is related to system management data flows only.
FR 6: Timely response to events	Audit, event monitoring	Events, logs	
FR 7: Resource availability	Backup, DDoS protection, emergency power	Port, role, power, and other commands	

Appendix C contains a mapping of the Redfish security functionality documented in O-PAS Part 5 – System Management compared to ANSI/ISA-62443-4-2 SL2 requirements.

4.3.3 Gap Assessment

Table 1 shows that Redfish provides a good basis for implementing the security requirements related to system management. However, there are some gaps in coverage. Redfish is focused on *system* management, and thus security requirements related to *network* management are out of scope in the O-PAS Standard, Version 2.1. Redfish provides an API which relies on the presence of several external services which also need to be secure. Additional gaps may include:

- Audit process failure notifications
- Protection of audit information
- Resource limits by security functions

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Protection of audit information and resource limits is outside the scope and capability of the system management interface as specified in O-PAS Part 5 – System Management. Regarding audit failure notifications, Redfish itself is only a protocol and data model so it cannot detect audit failures, but it does expose log and event functionality that can generate configuration change events.

The Redfish specification allows enabling/disabling of management protocols such as HTTP, Telnet, NTP, and older versions of SNMP which do not meet the security requirements in ANSI/ISA-62443-4-2. Product suppliers are advised to follow the requirements in O-PAS Part 5 – System Management related to non-secure management protocols. End users need to be aware that if such management protocols are present and enabled, that will result in non-conformance with SL2 capability required in this document.

Product suppliers and end users are advised to be aware that commercial hardware platforms, largely developed for IT (*versus* OT) application use, may contain Baseboard Management Controllers (BMCs) which have the potential to negatively impact deployment security. For example, a hardware BMC may contain functionality to support services which have been excluded from the O-PAS Standard; e.g., HTTP (*versus* HTTPS), TFTP, Telnet. Wherever possible, mitigation actions have to be employed to isolate, limit the scope of, and/or disable such undesirable BMC services. Specific recommendations would be platform-specific and are out of scope for this document.

See O-PAS Part 5 – System Management for details on these gaps.

4.4 O-PAS Part 6 – Information and Exchange Models

4.4.1 Mapping Download/Upload and Import/Export Formats to ANSI/ISA 62443

The import/export and download/upload models, defined in O-PAS Part 6.1 – Overview and Interfaces, rely on the creation and maintenance of configuration zip files in a form described by the Automation Markup Language (AutomationML[2]) standard. Since configuration data is of utmost importance for the operation of IACS and in many cases considered Intellectual Property (IP) by end users, it needs to be protected at all times, both in transit and at rest.

Considering that the configuration management tools required to implement the import/export format are outside the scope of the O-PAS Standard, the security requirements defined hereafter apply to the mechanisms to download/upload configuration data from/to the DCN, and to protect configuration data at rest while stored at the DCN. However, it is strongly recommended to equally apply the security requirements defined in this section to the configuration management tools supporting the functionality described in O-PAS Part 6 – Information and Data Exchange Models.

Table 2 provides an overview of security control foundational requirement areas and key component requirements of the ANSI/ISA-62443-4-2 standard necessary for protecting data in transit and at rest.

[2] See www.automationml.org.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Table 2: Data in Transit and At Rest ANSI/ISA-62443-4-2 SL2 Requirements

Title	ANSI/ISA-62443-4-2 Section	Description
FR 1: Identification and authentication control	5.2 Rationale	By extension, access control requirements need to be extended to data at rest.
FR 2: Use control	6.2 Rationale	By extension, use control requirements must be extended to data at rest.
FR 3: System integrity	7.2 Rationale	The integrity of logical assets needs to be maintained while in transit and at rest, such as being transmitted over a network or when residing in a data repository.
FR 4: Data confidentiality	8.2 Rationale	Some component-generated information, whether at rest or in transit, is of a confidential or sensitive nature. This implies that some communication channels and data stores require protection against eavesdropping and unauthorized access.
CR 4.1: Information confidentiality	8.3.1 Requirement	Components need to: • Provide the capability to protect the confidentiality of information at rest for which explicit read authorization is supported • Support the protection of the confidentiality of information in transit as defined in ANSI/ISA-62443-3-3, System Requirement 4.1
CR 4.2: Information persistence	8.4.1 Requirement	Components need to provide the capability to erase all information, for which explicit read authorization is supported, from components to be released from active service and/or decommissioned.
CR 4.3: Use of cryptography	8.5.1 Requirement	If cryptography is required, the component needs to use cryptographic security mechanisms according to internationally recognized and proven security practices and recommendations.

4.4.2 Gap Assessment

O-PAS Part 6 – Information and Exchange Models does not standardize the download/upload model for the O-PAS Standard, Version 2.1. Currently, the download/upload mechanism in support of the functionality defined in O-PAS Part 6 would be vendor-proprietary. Suppliers building O-PAS products for the functionality specified in O-PAS Part 6 would need to implement security capabilities for the protection of data in transit and at rest in conformance with ANSI/ISA-62443-4-2 SL2 requirements.

The AutomationML standard was not designed to address the needs for security of data at rest. ANSI/ISA-62443-4-2 requires protection of data from unauthorized export or copy. It is understood that proprietary information could be at risk with the use of AutomationML exports and countermeasures need to be implemented by product suppliers and end users.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

The OPAS Standard, Version 2.1 introduces the concept of execution engine within O-PAS Part 6.2 – Basic Configuration. The execution engine hosts function blocks that will control processes in the end user's application. Currently there is no established way of defining role-based access in function blocks configuration and use.

4.5 O-PAS Part 7 – Distributed Control Platform

4.5.1 Mapping of Distributed Control Platform to ANSI/ISA-62443-4-2

An O-PAS Distributed Control Platform (DCP) will follow a typical device lifecycle, which involves procurement, provisioning, deployment, and decommissioning.

Table 3 provides an overview of baseline component requirements of the ANSI/ISA-62443-4-2 standard necessary for embedded security capability of the physical platform. Additional requirements may apply.

Table 3: ANSI/ISA-62443-4-2 Baseline Requirements for Device Lifecycle Security

Device Lifecycle	Requirements
Procurement	EDR 2.13 & HDR 2.13: Use of physical diagnostic and test interfaces
	EDR 3.11 & HDR 3.11: Physical tamper resistance and detection
	EDR 3.12 & HDR 3.12: Provisioning product supplier roots of trust
	EDR 3.13 & HDR 3.13: Provisioning asset owner roots of trust
	EDR 3.14 & HDR 3.14: Boot integrity
	CR 5.1: Network segmentation
Provisioning	CR 7.6: Network and security configuration settings
	CR 7.7: Least functionality
Deployment	EDR 3.2 & HDR 3.2: Protection from malicious code
	EDR 3.10 & HDR 3.10: Support for updates
	CR 3.9: Protection of audit information
	CR 6.2: Continuous monitoring
	CR 7.3: Control system backup
	CR 7.4: Control system recovery and reconstitution

In order to support the above requirements, there are additional security features needed. The following table captures those requirements that are not specific to any phase of device lifecycle, but fundamental to supporting the above requirements.

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Device Lifecycle	Requirements
Authenticated access	CR 1.5: Authenticator management
Cryptography	CR 1.9: Strength of public key-based authentication
	CR 1.14: Strength of symmetric key-based authentication
	CR 4.3: Use of cryptography

4.5.2 Gap Assessment

ANSI/ISA-62443-4-2 specifies a requirement regarding information persistence (CR 4.2) when decommissioned. In addition, it is desired to reset the device to a factory image (default OEM configuration) when decommissioned. When this is not possible, it is advisable that at decommissioning time all stored contents (including software installed post-manufacturing, configuration information, and key material) have to be wiped clean.

While ANSI/ISA-62443-4-2 does not specifically call out the need for protected storage, it is implied (for instance, CR 3.9 for protecting logs or other protection of configuration and key material). Suppliers building O-PAS products for the functionality specified in O-PAS Part 7 – Distributed Control Platform would need to implement security capabilities for protected storage to comply with implied component requirements.

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

A SEC-F-001 Security Facet (Normative)

A product supporting SEC-F-001 shall support all requirements in ANSI/ISA-62443-4-2; the conformance requirements in Table 4 (marked with "CRQ" identifiers) provide traceability to individual requirements. All requirements apply unless the supplier demonstrates "not applicable" to the O-PAS product under consideration to the organization testing the security conformance against ANSI/ISA-62443-4-2.

Notes

1. Based on the O-PAS functionality defined in other parts of the O-PAS Standard, the component types defined in ANSI/ISA-62443-4-2 applicable to O-PAS products are software application, embedded device, and host device. Thus, Network Device Requirements (NDR) are not included in Table 4 for simplicity and readability.
2. Abbreviations used in Table 4 are defined in Section D.1.
3. The titles in Table 4 are direct references from the ANSI/ISA-62443-4-2 standard.

Table 4: Security Facet for the O-PAS Standard, Version 2.1

ANSI/ISA-62443-4-2 SL2 Requirements	Conformance Requirement ID
FR 1: Identification and authentication control	
CR 1.1: Human user identification and authentication	CRQ-P2-1001
CR 1.1 RE (1): Unique identification and authentication	CRQ-P2-1002
CR 1.2: Software process and device identification and authentication	CRQ-P2-1003
CR 1.3: Account management	CRQ-P2-1004
CR 1.4: Identifier management	CRQ-P2-1005
CR 1.5: Authenticator management	CRQ-P2-1006
CR 1.7: Strength of password-based authentication	CRQ-P2-1007
CR 1.8: Public key infrastructure certificate	CRQ-P2-1008
CR 1.9: Strength of public key-based authentication	CRQ-P2-1009
CR 1.10: Authenticator feedback	CRQ-P2-1010
CR 1.11: Unsuccessful login attempts	CRQ-P2-1011

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 Requirements	Conformance Requirement ID
CR 1.12: System use notification	CRQ-P2-1012
CR 1.14: Strength of symmetric key-based authentication	CRQ-P2-1013
FR 2 – Use control	
CR 2.1: Authorization enforcement	CRQ-P2-1101
CR 2.1 RE (1): Authorization enforcement for all users (humans, software processes, and devices)	CRQ-P2-1102
CR 2.1 RE (2): Permission mapping to roles	CRQ-P2-1103
CR 2.2: Wireless use control	CRQ-P2-1104
SAR 2.4: Mobile code	CRQ-P2-1105
SAR 2.4 RE (1): Mobile code authenticity check	CRQ-P2-1106
EDR 2.4: Mobile code	CRQ-P2-1107
EDR 2.4 RE (1): Mobile code authenticity check	CRQ-P2-1108
HDR 2.4: Mobile code	CRQ-P2-1109
HDR 2.4 RE (1): Mobile code authenticity check	CRQ-P2-1110
CR 2.5: Session lock	CRQ-P2-1111
CR 2.6: Remote session termination	CRQ-P2-1112
CR 2.8: Auditable events	CRQ-P2-1113
CR 2.9: Audit storage capacity	CRQ-P2-1114
CR 2.10: Response to audit processing failures	CRQ-P2-1115
CR 2.11: Timestamps	CRQ-P2-1116
CR 2.11 RE (1): Time synchronization	CRQ-P2-1117
CR 2.12: Non-repudiation	CRQ-P2-1118
EDR 2.13: Use of physical diagnostic and test interfaces	CRQ-P2-1119
HDR 2.13: Use of physical diagnostic and test interfaces	CRQ-P2-1120
FR 3: System integrity	
CR 3.1: Communication integrity	CRQ-P2-1201

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 Requirements	Conformance Requirement ID
CR 3.1 RE (1): Communication authentication	CRQ-P2-1202
SAR 3.2: Protection from malicious code	CRQ-P2-1203
EDR 3.2: Protection from malicious code	CRQ-P2-1204
HDR 3.2: Protection from malicious code	CRQ-P2-1205
HDR 3.2 RE (1): Report version of code protection	CRQ-P2-1206
CR 3.3: Security functionality verification	CRQ-P2-1207
CR 3.4: Software and information integrity	CRQ-P2-1208
CR 3.4 RE (1): Authenticity of software and information	CRQ-P2-1209
CR 3.5: Input validation	CRQ-P2-1210
CR 3.6: Deterministic output	CRQ-P2-1211
CR 3.7: Error handling	CRQ-P2-1212
CR 3.8: Session integrity	CRQ-P2-1213
CR 3.9: Protection of audit information	CRQ-P2-1214
EDR 3.10: Support for updates	CRQ-P2-1215
EDR 3.10 RE (1): Update authenticity and integrity	CRQ-P2-1216
HDR 3.10: Support for updates	CRQ-P2-1217
HDR 3.10 RE (1): Update authenticity and integrity	CRQ-P2-1218
EDR 3.11: Physical tamper resistance and detection	CRQ-P2-1219
HDR 3.11: Physical tamper resistance and detection	CRQ-P2-1220
EDR 3.12: Provisioning product supplier roots of trust	CRQ-P2-1221
HDR 3.12: Provisioning product supplier roots of trust	CRQ-P2-1222
EDR 3.13: Provisioning asset owner roots of trust	CRQ-P2-1223
HDR 3.13: Provisioning asset owner roots of trust	CRQ-P2-1224
EDR 3.14: Integrity of the boot process	CRQ-P2-1225
EDR 3.14 RE (1): Authenticity of the boot process	CRQ-P2-1226

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 Requirements	Conformance Requirement ID
HDR 3.14: Integrity of the boot process	CRQ-P2-1227
HDR 3.14 RE (1): Authenticity of the boot process	CRQ-P2-1228
FR 4: Data confidentiality	
CR 4.1: Information confidentiality	CRQ-P2-1301
CR 4.2: Information persistence	CRQ-P2-1302
CR 4.3: Use of cryptography	CRQ-P2-1303
FR 5: Restricted data flow	
CR 5.1: Network segmentation	CRQ-P2-1401
FR 6: Timely response to events	
CR 6.1: Audit log accessibility	CRQ-P2-1501
CR 6.2: Continuous monitoring	CRQ-P2-1502
FR 7: Resource availability	
CR 7.1: Denial of service protection	CRQ-P2-1601
CR 7.1 RE (1): Manage communication load from component	CRQ-P2-1602
CR 7.2: Resource management	CRQ-P2-1603
CR 7.3: Control system backup	CRQ-P2-1604
CR 7.3 RE (1): Backup integrity verification	CRQ-P2-1605
CR 7.4: Control system recovery and reconstitution	CRQ-P2-1606
CR 7.6: Network and security configuration settings	CRQ-P2-1607
CR 7.7: Least functionality	CRQ-P2-1608
CR 7.8: Control system component inventory	CRQ-P2-1609

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

B Overview of OPC UA Functionality (Informative)

Table 5 provides an overview of security-related functionality defined by the OPC UA standard (profiled in O-PAS Part 4 – O-PAS Connectivity Framework (OCF)) compared to ANSI/ISA-62443-4-2 SL2 requirements. The following categories describe the related OPC UA functionality column:

- Y: OPC UA functionality matching the ANSI/ISA 62443 requirement was identified
- P: OPC UA functionality partially matching the ANSI/ISA 62443 requirement was identified
- N: Functionality matching the ANSI/ISA 62443 requirement does not appear to be in scope of OPC UA

Note: This information is provided as a reference only for organizations or individuals building OPC UA-related *products* for the O-PAS Standard. For a set of OPC UA profiles and facets applicable to the O-PAS Standard, refer to O-PAS Part 4 – O-PAS Connectivity Framework (OCF).

Table 5: ANSI/ISA-62443-4-2 Mapping to OPC UA

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
FR 1: Identification and authentication control					
CR 1.1: Human user identification and authentication	Y	Part 4	7.36.6	IssuedIdentityToken	5.3.1.3, 5.3.1.4, 5.3.1.5, 5.3.2
		Part 6	6.5.2	JSON Web Token (JWT), JWT UserTokenPolicy	
		Part 7	5.3	Security User JWT IssuedToken, Security User JWT Token Policy, OPC UA Authority Profile	
RE (1): Unique identification and authentication	Y	Part 4	7.36.6	IssuedIdentityToken	5.3.1.3, 5.3.1.4, 5.3.1.5, 5.3.2
		Part 6	6.5.2	JSON Web Token (JWT), JWT UserTokenPolicy	

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
		Part 7	5.3	Security User JWT IssuedToken, Security User JWT Token Policy, OPC UA Authority Profile	
			6.6.172, 6.6.177	User Token JWT Server Facet, User Token JWT Client Facet	
CR 1.2: Software process and device identification and authentication	Y	Part 2	4.10, 5.2.2	ApplicationAuthentication, X.509 v3 Security Certificates	5.3.1.4, 5.3.1.5, 5.3.2
		Part 4	6.1.2	Application Instance Security Certificate	
		Part 4	7.10, 5.4, 5.5	EndpointDescription, EndpointUrl, Hostname (Device)	
		Part 7	5.3, 6.6.9	Security Default ApplicationInstance Security Certificate, Global Security Certificate Management Server Facet	
CR 1.3: Account management	N				
CR 1.4: Identifier management	Y	Part 4	7.36, 7.37	UserIdentityToken, UserTokenPolicy	5.3.1.3, 5.3.1.4, 5.3.1.5, 5.3.2
		Part 7	5.3	Security User JWT IssuedToken, Security User JWT Token Policy, OPC UA Authority Profile	
			6.6.172, 6.6.177	User Token JWT Server Facet, User Token JWT Client Facet	
CR 1.5: Authenticator management	Y	Part 4	7.36, 7.37	UserIdentityToken, UserTokenPolicy	5.3.1.3, 5.3.1.4, 5.3.1.5, 5.3.2
		Part 7	5.3	Security User JWT IssuedToken, Security User JWT Token Policy, OPC UA Authority Profile	
			6.6.172, 6.6.177	User Token JWT Server Facet, User Token JWT Client Facet	
CR 1.7: Strength of password-based authentication	N				

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
CR 1.8: Security certificates	Y	Part 2	4.5.2, 4.10, 4.13	Security Certificates, TrustLists (CertificateStore), OPC UA Security Services	5.3.1.3, 5.3.1.5, 5.3.2
		Part 4	6.1.2, 6.1.3, 6.1.4	Obtaining, validating, and installing Security Certificate services	
		Part 6	6.2	Security Certificates	
		Part 7	5.3, 6.6.9, 6.6.80	Security Administration, Global Security Certificate Management	
		Part 12	7	Security Certificate Management Overview	
CR 1.9: Strength of public key-based authentication	Y	Part 2	6.8	Cryptographic Keys	5.3.1.3, 5.3.1.5, 5.3.2
		Part 4	6.1.3, 6.1.4	Trusted Security Certificates	
		Part 7	5.3	Security Profiles: Basic256_Limits, SecurityPolicy [B] – Basic256Sha256	
CR 1.10: Authenticator feedback	N				
CR 1.11: Unsuccessful login attempts	N				
CR 1.12: System use notification	N				
CR 1.14: Strength of symmetric key-based authentication	Y	Part 2	4.5.3.2, 5.2.5. 5.2.6	Symmetric Encryption	5.3.1.8, 5.3.3
		Part 6	Table 43	SymmetricEncryptionAlgorithm	
		Part 7	6.6.11, 6.6.81, 6.6.185, 6.6.186	Global Service Key Credential Pull/Push Facets, KeyCredential Service Server Facet, KeyCredential Service Client Facet	
		Part 14	5.4.3, Table 74	Security Key Service (SKS), SymmetricEncryptionAlgorithm	

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
FR 2: Use control					
CR 2.1: Authorization enforcement	Y	Part 2	4.2.3, 4.5, 4.11, 5.2.4, 6.12	UserAuthorization	5.3.2, 5.3.1.5
		Part 4	6.2, 7.36	Authorization Services, IssuedIdentityToken	
		Part 6	6.5.2	AuthorizationService, JSON Web Token (JWT)	
		Part 7	6.6.172, 6.6.177	User Token – JWT Server Facet, User Token – JWT Client Facet	
RE (1): Authorization enforcement for all users (humans, software processes, and devices)	Y	Part 2	4.2.3, 4.5, 4.12, 5.2.4, 6.12	UserAuthorization	5.3.1.3, 5.3.1.5, 5.3.2
		Part 4	6.2, 7.36	Authorization Services, IssuedIdentityToken	
		Part 6	6.5.2	AuthorizationService, JSON Web Token (JWT)	
		Part 7	6.6.172, 6.6.177	User Token – JWT Server Facet, User Token – JWT Client Facet	
RE (2): Permission mapping to roles	Y	Part 2	4.12, 6.12	Roles, JWT, and User Roles	5.3.1.3, 5.3.1.5, 5.3.2
		Part 5	Annex F	User Authorization, Role Type	
		Part 6	Annex F, F.5	RolePermissions	
		Part 7	6.6.43, 6.6.223	User Role Management Server/Client Facets	
CR 2.2: Wireless use control	N				
SAR 2.4: Mobile code	N				
RE (1): Mobile code authenticity check	N				
EDR 2.4: Mobile code	N				

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
RE (1): Mobile code authenticity check	N				
HDR 2.4: Mobile code	N				
RE (1): Mobile code authenticity check	N				
CR 2.5: Session lock	N				
CR 2.6: Remote session termination	N				
CR 2.8: Auditable events	Y	Part 2	4.2.7, 4.14, 6.11	Auditability, Auditing, Audit Event Management	5.3.2
		Part 4	6.5	Auditing	
		Part 5	6.4.4	AuditSecurityEventType	
		Part 7	6.6.40, 6.6.110, 6.6.152, 6.6.158	Auditing Server Facet, Auditing Client Facet, Best Practice – Audit Events	
CR 2.9: Audit storage capacity	N				
CR 2.10: Response to audit processing failures	N				
CR 2.11: Timestamps	Y	Part 2	5.1.6	Message replay, Timestamps,SecureChannelID	5.3.2
		Part 4	7.35	TimestampsToReturn	
		Part 5	6.4.3	AuditEventType	
		Part 7	6.6.40	Auditing Server Facet	
RE (1): Time synchronization	Y	Part 2	6.8	Cryptographic Keys (time validity of security profile)	5.3.1.3, 5.3.14, 5.3.1.5, 5.3.2
		Part 4	7.7.3, 7.38, 6.6.2.2	SourceTimestamp, VersionTime, Redundant Server Set Requirements	
		Part 6	6.3	Time Synchronization	

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
		Part 7	6.6.151	Security Time Synchronization	
CR 2.12: Non-repudiation	Y	Part 2	4.2.6, 4.3.5, 4.3.8, 4.3.9, 4.2.13, 6.11	Message alteration, Server Profiling, System Hijacking, Repudiation, Audit Event Management	5.1.3.5, 5.3.2
		Part 4	5.1.5, 5.1.8, 5.1.9, 5.1.12, 6.5	Signing, GetEndpoints, SecureChannel, Auditing, Proof of Possession, UserTokenPolicy (user), SecurityPolicy (endpoint)	
		Part 7	6.6.172, 6.6.172, 6.6.40, 6.6.110, 6.6.152	User Token – JWT Server/Client Facets, Auditing Server Facet, Auditing Client Facet, Best Practice – Audit Events	
EDR 2.13: Use of physical diagnostic and test interfaces	N				
HDR 2.13: Use of physical diagnostic and test interfaces	N				
FR 3: System integrity					
CR 3.1: Communication integrity	Y	Part 2	4.13, 4.2.5, 4.5.2	Secure Channel – OpenSecureChannel	5.3.1.4, 5.3.1.5, 5.3.2
		Part 4	5.5, 5.5.2	Secure Channel Service Set	
		Part 6	4, 7.1.3	Secure Channel, SecurityProtocol	
		Part 7	5.3, 6.6.164, 6.6.165	Security Policy Required, Security Policy [A] & [B]	
RE (1): Communication authentication	Y	Part 2	4.13, 4.2.5, 4.5.2	Secure Channel – OpenSecureChannel	5.3.1.4, 5.3.1.5, 5.3.2
		Part 4	5.5, 5.5.2	Secure Channel Service Set	
		Part 6	4, 7.1.3	Secure Channel	
		Part 7	5.3, 6.6.164, 6.6.165	Security Policy Required, Security Policy [A] & [B]	
SAR 3.2: Protection from malicious code	N				

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
EDR 3.2: Protection from malicious code	N				
HDR 3.2: Protection from malicious code	N				
RE (1): Report version of code protection	N				
CR 3.3: Security functionality verification	Y	Part 2	4.1	Identity Provider, Security Key Service, Secure Channel, TLS	5.3.1.4, 5.3.1.5, 5.3.2
		Part 4	5.5.2, 5.6.2, 5.10.4	OpenSecureChannel, CreateSession, Write	
		Part 6	6.7.1, 6.7.4, 6.7.6	OPC UA Secure Conversation (UASC), Verifying Message Security, Token Policy, Bad_SecureChannel	
		Part 7	6.6.172, 6.6177, 6.6.164, 6.6.165	User Token – JWT Server/Client facets, Security Policy [A] & [B]	
CR 3.4: Software and information integrity	Y	Part 2	3.1.4, 4.2.5	Application Instance Security Certificate	5.3.1.4, 5.3.1.5, 5.3.2
		Part 4	4.8.1, 6.4, 7.33	SoftwareCertificates	
		Part 6	6.6.2, 7.5.3	Application Instance Security Certificate, X.509 v3	
		Part 7	5.3	Security ApplicationInstance Security Certificate, Global Security Certificate Management Server/Client Profiles	
RE (1): Authenticity of software and information	N				
CR 3.5: Input validation	N				
CR 3.6: Deterministic output	N				
CR 3.7: Error handling	Y	Part 4	4.2	Request/Response Service	5.3.1.4, 5.3.1.5, 5.3.2
		Part 5	6.3.5	SessionDiagnosticsObjectType	

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
		Part 6	6.7.3, 7.1.5	MessageChunks, Error Handling, Error Message, CloseSecureChannel	
		Part 7	5.3, 6.6.164, 6.6.165	Security Policy Required, Security Policy [A] & [B]	
CR 3.8: Session integrity	Y	Part 2	5.1.9	Secure Channel, Session ID	5.3.2
		Part 4	5.5.2, 5.6, 6.1.5, 6.5.6, 7.31	Session Service Set, Creating a Session, Auditing Session Service, SessionAutenticationToken	
		Part 7	Table 4	Session Services Facets, Standard UA Client 2017 Profile, Base Server Behavior Facet	
CR 3.9: Protection of audit information	N				
EDR 3.10: Support for updates	N				
RE (1): Update authenticity and integrity	N				
HDR 3.10: Support for updates	N				
RE (1): Update authenticity and integrity	N				
EDR 3.11: Physical tamper resistance and detection	N				
HDR 3.11: Physical tamper resistance and detection	N				
EDR 3.12: Provisioning product supplier roots of trust	N	Part 21, RC xxx	OPC UA specification under development		

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
HDR 3.12: Provisioning product supplier roots of trust	N	Part 21, RC xxx	OPC UA specification under development		
EDR 3.13: Provisioning asset owner roots of trust	N	Part 21, RC xxx	OPC UA specification under development		
HDR 3.13: Provisioning asset owner roots of trust	N	Part 21, RC xxx	OPC UA specification under development		
EDR 3.14: Integrity of the boot process	N				
RE (1): Authenticity of the boot process	N				
HDR 3.14: Integrity of the boot process	N				
RE (1): Authenticity of the boot process	N				
FR 4: Data confidentiality					
CR 4.1: Information confidentiality	Y	Part 2	3.1.17, 4.2.4. 4.3.3, 4.5.2, 4.5.3, 5.2.5	Confidentiality, Confidentiality, Eavesdropping, Client/Server, PubSub, Confidentiality	5.3.1.5, 5.3.2
		Part 4	5.5	SecureChannel Service Set	
		Part 6	7.4, 7.5.3	OPC UA HTTPS, WebSockets (Security)	
		Part 7	5.3, 6.6.164, 6.6.165	Security Policy Required, Security Policy [A] & [B]	
CR 4.2: Information persistence	N				

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
CR 4.3: Use of cryptography	Y	Part 2	3.1.5, 3.1.18, 3.1.40, 4.6, 6.4, 8	Asymmetric Cryptography, Cryptography, Symmetric Cryptography, SecurityPolicies, Random Number Generation, Security Certificate Management	5.3.2
		Part 4	5.4.4., 5.5.2	GetEndpoints, OpenSecureChannel	
		Part 6	6.1, 6.2, 6.5.3.2, 6.7.2.3, 6.7.5	Security Handshake, Security Certificates, Access Tokens, Security Header, Deriving Keys (Table 49)	
		Part 7	6.6.82, 6.6.150, 6.6.154, 6.6.181, 6.6.183	Access Token Request Client Facet, Security User Access Control Base Profile, Best Practice – Random Numbers, Global Discovery and Security Certificate Management 2017 Server, Global Security Certificate Management Client 2017 Profile	
FR 5: Restricted data flow					
CR 5.1: Network segmentation	Y	Part 2	4.1, 4.5	Network Segmentation, OpenSecureChannel	5.3.2
		Part 4	5.5	Transport Layer – LS, Communication Layer – Secure Channel, Application Layer – Session for Auth	
		Part 7	Table 4	Standard UA Client 2017 Profile, Base Server Behavior Facet	
FR 6: Timely response to events					
CR 6.1: Audit log accessibility	N				
CR 6.2: Continuous monitoring	Y	Part 7	5.2 Table	Monitor Items, GetMonitoredItems Method, SetMonitoringMode	5.3.2
				Subscription Server Facet, Standard UA Client 2017 Profile, Standard DataChange Subscription 2017 Server Facet	

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
FR 7: Resource availability					
CR 7.1: Denial of service protection	Y	Part 2	5.1.2, 5.1.2.4	Application Crashes, Fuzz Testing, Certification	5.3.2
		Part 4	5.6.2, 5.6.2.1	CreateSession, OpenSecureChannel, AuthenticationToken	
		Part 7	Table 4	Session Services Facets, Standard UA Client 2017 Profile, Base Server Behavior Facet	
RE (1): Manage communication load from component	Y	Part 2	5.1.2, 5.1.2.2	Message flooding, GetEndpoints, OpenSecureChannel	5.3.2
		Part 4	5.6.2	CreateSession, OpenSecureChannel, AuthenticationToken	
		Part 7	Table 4	Session Services Facets, Standard UA Client 2017 Profile, Base Server Behavior Facet	
CR 7.2: Resource management	Y	Part 2	5.1.2, 5.1.2.3	Resource exhaustion, ClientAuthentication, ServerAuditing, OpenSecureChannel	5.3.2
		Part 4	5.6.2	CreateSession, OpenSecureChannel, AuthenticationToken	
		Part 7	Table 4	Session Services Facets, Standard UA Client 2017 Profile, Base Server Behavior Facet	
CR 7.3: Control system backup	N				
RE (1): Backup integrity verification	N				
CR 7.4: Control system recovery and reconstitution	N				
CR 7.6: Network and security configuration settings	N				

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 CRs and REs	Related OPC UA Functionality	OPC UA Version (RC 1.04) Part #	OPC UA Specification Section	OPC UA Reference Service/Profile/ Facet/Conformance Unit (CU)	O-PAS Part 4 Reference Section(s)
CR 7.7: Least functionality	N				
CR 7.8: Control system component inventory	N				

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

C Overview of Redfish Functionality (Informative)

Table 6 provides an overview of security-related functionality defined by the Redfish standard (profiled in O-PAS Part 5 – System Management) compared to ANSI/ISA-62443-4-2 SL2 requirements. The following categories describe the related Redfish functionality column:

- Y: Redfish functionality matching the ANSI/ISA 62443 requirement was identified
- P: Redfish functionality partially matching the ANSI/ISA 62443 requirement was identified
- N: Functionality matching the ANSI/ISA 62443 requirement does not appear to be in scope of the Redfish standard

Note: This information is provided as a reference only for organizations or individuals building Redfish-related products for the O-PAS Standard. For a set of Redfish resources and properties applicable to the O-PAS Standard, refer to O-PAS Part 5 – System Management.

Table 6: ANSI/ISA-62443-4-2 Mapping to the Redfish Standard

ANSI/ISA-62443-4-2 SL2 O-PAS Relevant CRs and REs	Related Redfish Functionality	Redfish Primary Resource(s)/Comment	O-PAS Part 5 Reference Section(s)
FR 1: Identification and authentication control			
CR 1.1: Human user identification and authentication	Y	AccountService, ManagerAccount	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
RE (1): Unique identification and authentication	Y	AccountService, ManagerAccount	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.2: Software process and device identification and authentication	Y	NetworkAdapter, Security Certificate, AccountService	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.3: Account management	Y	AccountService, ManagerAccount	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.4: Identifier management	Y	AccountService, ManagerAccount	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.5: Authenticator management	Y	AccountService, ManagerAccount	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 O-PAS Relevant CRs and REs	Related Redfish Functionality	Redfish Primary Resource(s)/Comment	O-PAS Part 5 Reference Section(s)
CR 1.7: Strength of password-based authentication	P	AccountService, ManagerAccount Through external Account Management Service only	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.8: Security certificates	Y	Security Certificate, CertificateService, AccountService	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.9: Strength of public key-based authentication	Y	Security Certificate, CertificateService, AccountService	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.10: Authenticator feedback	Y	AccountService, ManagerAccount	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.11: Unsuccessful login attempts	Y	AccountService, ManagerAccount	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.12: System use notification	Y	AccountService, ManagerAccount	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 1.14: Strength of symmetric key-based authentication	N		
FR 2: Use control			
CR 2.1: Authorization enforcement	Y	AccountService, ManagerAccount, Role	5.4.2, 5.5, 6.3.3, C.1.9, C.2.1, Appendix D
RE (1): Authorization enforcement for all users (humans, software processes, and devices)	Y	AccountService, ManagerAccount, Role	5.4.2, 5.5, 6.3.3, C.1.9, C.2.1, Appendix D
RE (2): Permission mapping to roles	Y	AccountService, ManagerAccount, Role	5.4.2, 5.5, 6.3.3, C.1.9, C.2.1, Appendix D
CR 2.2: Wireless use control	N		
SAR 2.4: Mobile code	N		
RE (1): Mobile code authenticity check	N		
EDR 2.4: Mobile code	N		
RE (1): Mobile code authenticity check	N		

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 O-PAS Relevant CRs and REs	Related Redfish Functionality	Redfish Primary Resource(s)/Comment	O-PAS Part 5 Reference Section(s)
HDR 2.4: Mobile code	N		
RE (1): Mobile code authenticity check	N		
CR 2.5: Session lock	Y	Manager, ServiceRoot, Session, SessionService	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 2.6: Remote session termination	Y	Manager, ServiceRoot, Session, SessionService	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 2.8: Auditable events	Y	EventService, LogService, RemoteLoggingAgent	5.4.2, 5.5, 6.3.3, C.1.3, Appendix D
CR 2.9: Audit storage capacity	N		
CR 2.10: Response to audit processing failures	Y	EventService, LogService, RemoteLoggingAgent	5.4.2, 5.5, 6.3.3, C.1.3, Appendix D
CR 2.11: Timestamps	Y	LogEntry, MetricReport, OperatingSystemMetrics, DCNExecutionEngineMetrics	5.4.2, 5.5, 6.3.3, C.1.3, Appendix D
RE (1): Time synchronization	Y	MetricDefinitionManager, ManagerNetworkProtocol	5.4.2, 5.5, 6.3.3, C.1.9
CR 2.12: Non-repudiation	Y	EventService, LogService, RemoteLoggingAgent, EventDestination, LogEntry	5.4.2, 5.5, 6.3.3, C.1.3, Appendix D
EDR 2.13: Use of physical diagnostic and test interfaces	N		
HDR 2.13: Use of physical diagnostic and test interfaces	N		
FR 3: System integrity			
CR 3.1: Communication integrity	Y	ManagerNetworkProtocol, Security Certificate, CertificateService	5.4.2, 5.5, 6.3.3, D.1.28, Appendix D
RE (1): Communication authentication	Y	ManagerNetworkProtocol, Security Certificate, CertificateService	5.4.2, 5.5, 6.3.3, D.1.28, Appendix D
SAR 3.2: Protection from malicious code	N		

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 O-PAS Relevant CRs and REs	Related Redfish Functionality	Redfish Primary Resource(s)/Comment	O-PAS Part 5 Reference Section(s)
EDR 3.2: Protection from malicious code	N		
HDR 3.2: Protection from malicious code	N		
RE (1): Report version of code protection	N		
CR 3.3: Security functionality verification	Y	Refer to the security requirements in O-PAS Part 5 – System Management	5.5, 5.5.1
CR 3.4: Software and information integrity	N		
RE (1): Authenticity of software and information	N		
CR 3.5: Input validation	N		
CR 3.6: Deterministic output	N		
CR 3.7: Error handling	Y	EventService, LogService, RemoteLoggingAgent, EventDestination, LogEntry	5.4.2, 5.5, 6.3.3, C.1.3, Appendix D
CR 3.8: Session integrity	Y	Session, SessionService	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 3.9: Protection of audit information	N		
EDR 3.10: Support for updates	N		
RE (1): Update authenticity and integrity	N		
HDR 3.10: Support for updates	N		
RE (1): Update authenticity and integrity	N		
EDR 3.11: Physical tamper resistance and detection	N		
HDR 3.11: Physical tamper resistance and detection	N		

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 O-PAS Relevant CRs and REs	Related Redfish Functionality	Redfish Primary Resource(s)/Comment	O-PAS Part 5 Reference Section(s)
EDR 3.12: Provisioning product supplier roots of trust	N		
HDR 3.12: Provisioning product supplier roots of trust	N		
EDR 3.13: Provisioning asset owner roots of trust	N		
HDR 3.13: Provisioning asset owner roots of trust	N		
EDR 3.14: Integrity of the boot process	P	SecureBoot, ComputerSystem Properties for managing the UEFI secure boot functionality of a system	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
RE (1): Authenticity of the boot process	N		
HDR 3.14: Integrity of the boot process	P	SecureBoot, ComputerSystem Properties for managing the UEFI secure boot functionality of a system	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
RE (1): Authenticity of the boot process	N		
FR 4: Data confidentiality			
CR 4.1: Information confidentiality	Y	ManagerNetworkProtocol, Security Certificate, CertificateService, Drive	5.4.2, 5.5, 6.3.3, Appendix D
CR 4.2: Information persistence	N		
CR 4.3: Use of cryptography	Y	Security Certificate, CertificateService, Drive	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
FR 5: Restricted data flow			
CR 5.1: Network segmentation	N		
FR 6: Timely response to events			
CR 6.1: Audit log accessibility	N		

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

ANSI/ISA-62443-4-2 SL2 O-PAS Relevant CRs and REs	Related Redfish Functionality	Redfish Primary Resource(s)/Comment	O-PAS Part 5 Reference Section(s)
CR 6.2: Continuous monitoring	Y	EventService, LogService, RemoteLoggingAgent, EventDestination, LogEntry	5.4.2, 5.5, 6.3.3, C.1.3, Appendix D
FR 7: Resource availability			
CR 7.1: Denial of service protection	Y	NetworkPort	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
RE (1): Manage communication load from component	Y	NetworkPort	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 7.2: Resource management	Y	NetworkPort	5.4.2, 5.5, 6.3.3, C.1.9, Appendix D
CR 7.3: Control system backup	N		
RE (1): Backup integrity verification	N		
CR 7.4: Control system recovery and reconstitution	N		
CR 7.6: Network and security configuration settings	Y	AccountService, ComputerSystem, ManagerAccount, Role	5.4.2, 5.5, 6.3.3, C.1.9, C.2.1, Appendix D
CR 7.7: Least functionality	Y	/refer to O-PAS Part 5 System Management Security Requirements	5.5, 5.5.1
CR 7.8: Control system component inventory	Y	Chassis, Drive, ComputerSystem, Memory, SoftwareInventory	5.4.2, 5.5, 6.3.3, C.1.9, C.2.2, Appendix D

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

D Abbreviations

For the OPAF Glossary and Abbreviations, see the definitions at: www.opengroup.org/open-process-automation-forum/glossary.

D.1 Abbreviations Specific to Part 2

The following abbreviations are specific to O-PAS Part 2 (and therefore do not appear in the OPAF Glossary referenced above).

Abbreviation	Definition
CCSC	Common Component Security Constraint
FR	Foundational Requirement
CR	Component Requirement
RE	Requirement Enhancement
SAR	Software Application Requirement
EDR	Embedded Device Requirement
HDR	Host Device Requirement
NDR	Network Device Requirement

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution

Index

accountability 7
anomaly detection..... 7
ANSI/ISA 62443 standards 2, 8
auditability..... 7
authentication 7
authorization..... 7
AutomationML..... 18
availability..... 6
BMC..... 18
certification..... 14
confidentiality..... 6
conformance 2, 12, 14
cybersecurity 1
DCN 1
DCP 20
DMTF..... 16
DoS..... 6
execution engine..... 20
firewall 7
IACS..... 2, 6
identification..... 7
IEEE 1588-2008 15
IIoT..... 6
incident response..... 7
integrity 6
JSON 16
NDR 22
non-repudiation 7
OData 16
OPC UA 13, 14, 26
PTP..... 15
Redfish 18
Redfish standard..... 13, 16, 38
RESTful interfaces..... 16
SEC-F-001 22
Security Architecture
Framework..... 1, 6
security controls 7
Security Level 11
security objectives..... 6
security requirements 26
segmentation 7
TLV..... 15
TSN 15
VLAN..... 7

Evaluation Copy

© 2021 The Open Group, All Rights Reserved
Evaluation Copy. Not for redistribution